

OPENCHAIN

Session 4: SBOM最前線

OpenChain Japan Community Day vol.36 (OpenChain Japan & OpenSSF Collaboration Event)

2026年10月22日

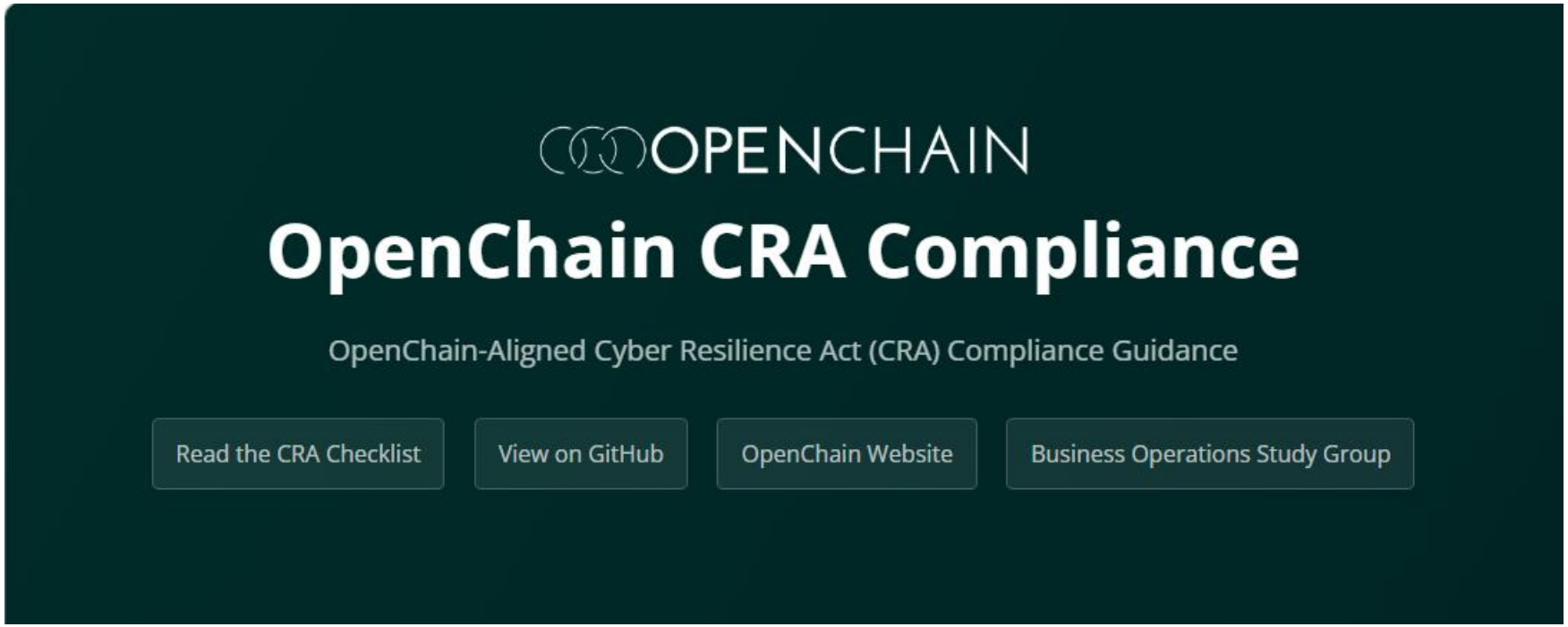
株式会社日立ソリューションズ　渡邊歩



OpenChain CRA Compliance Requirements & Checklist

OPENCHAIN

OpenChain CRA Compliance Requirements & Checklist



CRA対応のための実装ガイド兼自己評価ツール

OpenChain ISO/IEC 5230、OpenChain ISO/IEC 18974、SBOM Guide、Security Assurance SpecificationなどのOpenChain成果物を活用しながらCRA対応を実現する考え方を採用している点が特徴

OpenChain CRA Compliance Requirements & Checklist

■ CRA対応における企業の課題

- 自社は CRA 上どの役割（Manufacturer / Importer / Distributor / OSS Steward）に該当するのか分からない
- CRA の要求事項を開発・OSS管理・SBOM運用へどう落とし込めばよいか分からない
- SBOM、脆弱性管理、VEX、セキュリティアップデートの要求事項を体系的に整理したい
- CRA適合を示すためのエビデンス（証跡）をどのように残せばよいか分からない
- 現状の取り組みとCRA要求とのギャップを把握したい

法務・開発・PSIRT・OSPO・調達を横断するCRA対応チーム全体のセルフアセスメントツール

主な読者	活用するべき章
SBOM担当者	Section 3, 4, 7
OSPO担当者	Section 3, 5
PSIRT担当者	Section 4, 6
CRAプロジェクト責任者	Section 1〜9
OSS Steward	Section 5

OpenChainの規格と親和性が高い

OpenChain CRA Compliance Requirements & Checklist

区分	章	タイトル	この章の役割	主な内容
導入	Section 1	Introduction & Scope	本ドキュメントの目的・適用範囲を定義	CRA対象者、対象製品、役割（Manufacturer、Importer、Distributor、OSS Steward）、利用方法
ガバナンス	Section 2	Program Architecture & Governance	CRA対応のための組織体制・運営ルールを定義	ポリシー、責任体制、教育、リスクアセスメント、適合評価方針
チェックリスト本体	Section 3	Component Management & SBOM Quality	SBOM・ソフトウェア構成管理に関する要求事項	SBOM、依存関係管理、Provenance、ソフトウェア識別子、Secure Development
	Section 4	Vulnerability Handling & Vulnerability Exchange	脆弱性管理に関する要求事項	脆弱性監視、VEX、CSAF、リスク評価、Art.14報告
	Section 5	Open Source Software Stewardship	OSS Steward向けの要求事項・ガイダンス	OSS Stewardの責任、Maintainersとの責任分界、OSS管理
	Section 6	Security Updates & Support Period	製品出荷後の保守・サポート要求事項	サポート期間、セキュリティアップデート、EOL管理
	Section 7	Technical File & Supply Chain Sharing	CRA適合の証跡・成果物管理	Technical File、SBOM提供、EU Declaration of Conformity、CEマーキング
応用・拡張	Section 8	Cross-Framework Integration	他法規・他フレームワークとの関連整理	NIS2、AI Act、DORA、Data Act、eIDASとの整合
	Section 9	Procurement & Buyer-Side Obligations	調達・サプライヤ管理向け要求事項	ベンダ評価、CRA適合確認、SBOM要求、契約管理
実装支援	Implementation Roadmap	CRA Implementation Roadmap	CRA導入を進めるための推奨手順	優先順位付け、導入ステップ、成熟化計画
付録	Annex A	Glossary	用語集	CRA・SBOM・OSS関連用語の定義
	Annex B	CRA Traceability Matrix	要求事項対応表	CRA Annex I とチェックリスト項目のマッピング
	Annex C	Cross-Reference Mapping	他規格との対応表	ISO/IEC 18974、OWASP SAMM等との対応関係
	Annex D	External References & Adoption	外部参考資料・採用状況	関連プロジェクト、ガイド、コミュニティ活動
	References	References	参考文献一覧	CRA本文、規格、標準、ガイドライン

OpenChain CRA Compliance Requirements & Checklist

Section 3: Component Management & SBOM Quality

This section governs the quality and integrity of SBOMs. CRA Article 13 requires manufacturers to document components with sufficient granularity to identify known vulnerabilities. OpenChain ISO/IEC 18974 requires a documented process for component identification and vulnerability tracking.

3.1 Software Identification & Bill of Materials

Processes for generating machine-readable SBOMs for all released products. CRA requires SBOMs covering at the very least the top-level dependencies of those products.

Ref	Requirement	Conformant? (Yes / No / Partial)	Evidence & Rationale	Guidance / Reference
3.1.1	[CRA REQUIREMENT] The organization must maintain a documented process for generating machine-readable SBOMs for all released products, covering at the very least the top-level dependencies of those products.	☐ Yes ☐ No ☐ Partial		SBOM generation procedure; tool configuration (e.g., Syft, Trivy, CycloneDX CLI). Reference: BSI TR-03183.
3.1.2	[CRA REQUIREMENT] SBOMs must be produced in a commonly used, machine-readable format, such as a currently supported version of SPDX or CycloneDX, and must comply with any applicable implementing acts, harmonized standards, or common specifications.	☐ Yes ☐ No ☐ Partial		Sample SBOM file; format validation report. Reference: BSI TR-03183-2 for SBOM content requirements.
3.1.3	[GOOD PRACTICE] SBOM generation should be integrated into the software delivery pipeline and produce an artifact	☐ Yes ☐ No ☐ Partial		Software delivery pipeline configuration excerpt; build artifact manifest.

■ チェックリストの使い方

① 自組織が Manufacturer、Importer、Distributor、OSS Steward のどの役割に該当するかを特定する(1つの組織が複数の役割を持つこともある)

② 該当する役割について、対応するセクションのチェックリストを用いてチェックを実施する

■ Requirement Typeの凡例

① CRA適合のために満たす必要がある事項
- [CRA REQUIREMENT]
- [DIRECT CRA OBLIGATION]

② 監査やTechnical Fileで説明する際のエビデンスになる事項
- [CONFORMITY EVIDENCE / IMPLEMENTATION CONTROL]

③ CRA対応を効率的・確実にするための推奨事項
- [GOOD PRACTICE]
- [GOOD PRACTICE / IMPLEMENTATION CONTROL]

④ 法務判断やSBOM運用など、特定分野向けの補助的ラベル
- [LEGAL REVIEW / IMPLEMENTATION CONTROL]
- [ORGANIZATION SBOM PROFILE / IMPLEMENTATION CONTROL]

OpenChain CRA Compliance Requirements & Checklist

Project Information

The CRA Checklist is a workstream inside the OpenChain Business Operations Study Group.

The document is actively maintained with a **version 2 release planned in 2027**.

For active discussion and feedback, everyone is invited to join the Study Group meetings and mailing list:

- Calendar
  - OpenChain Business Operations Study Group EU/ASIA on Monday 11:00 UTC (bi-weekly)
  - OpenChain Business Operations Study Group NA/EU (CRA Checklist focus) on Tuesday 14:00 UTC
- Mailing list



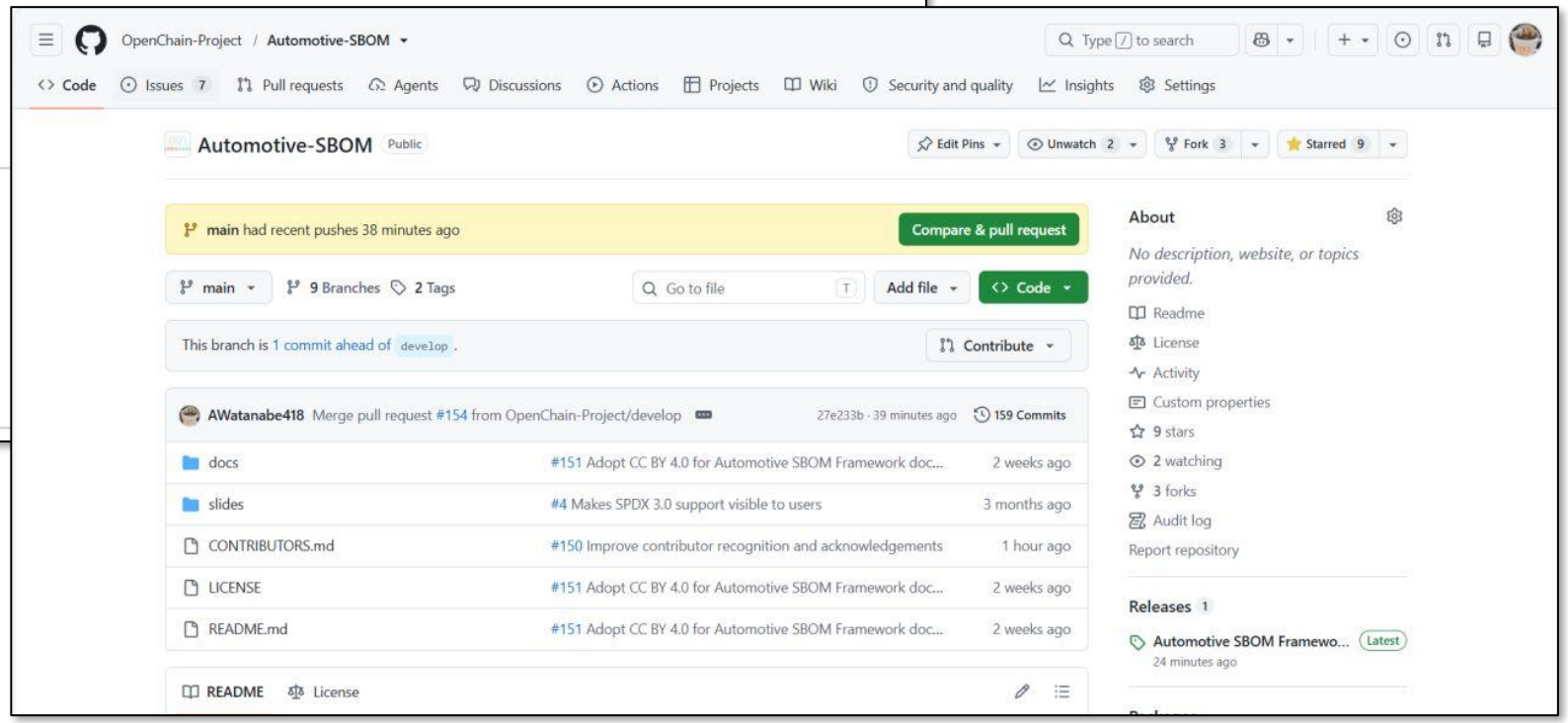
Automotive SBOM + SEPIA

OPENCHAIN

Automotive SBOM Framework v1.0 release

Linux Foundation Releases OpenChain Automotive SBOM Framework 1.0 for Greater Reliability and Traceability in Automotive Software

NEWS PROVIDED BY
The Linux Foundation →
Oct 07, 2026, 03:00 ET



Automotive SBOM

OPENCHAIN AUTOMOTIVE WORK GROUP

Automotive SBOM Framework v1.0

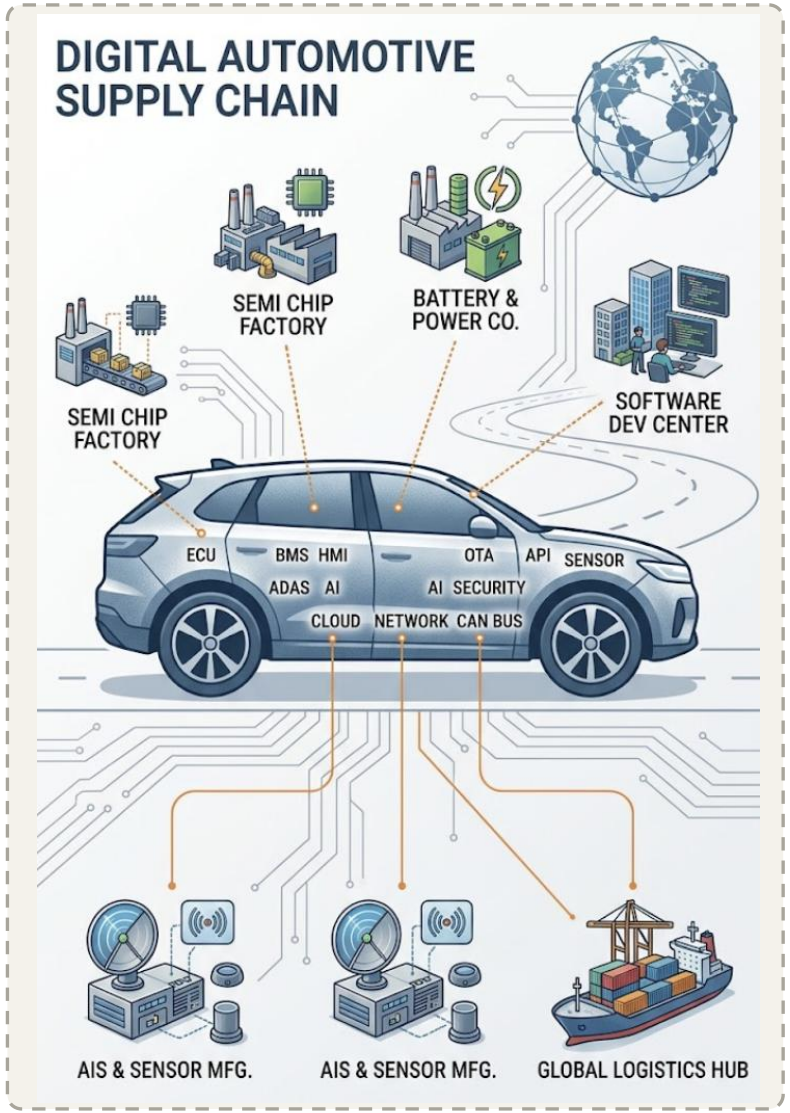
A shared best practice for automotive supply chains

Masato Endo · Automotive Chair and Board Member of OpenChain Project

Ayumi Watanabe · Hitachi Solutions, Ltd.

Mary Meixia Wang · Executive Director for OpenChain

Keisuke Takase · Toyota Motor Corporation



github.com/OpenChain-Project/Automotive-SBOM

Automotive SBOM

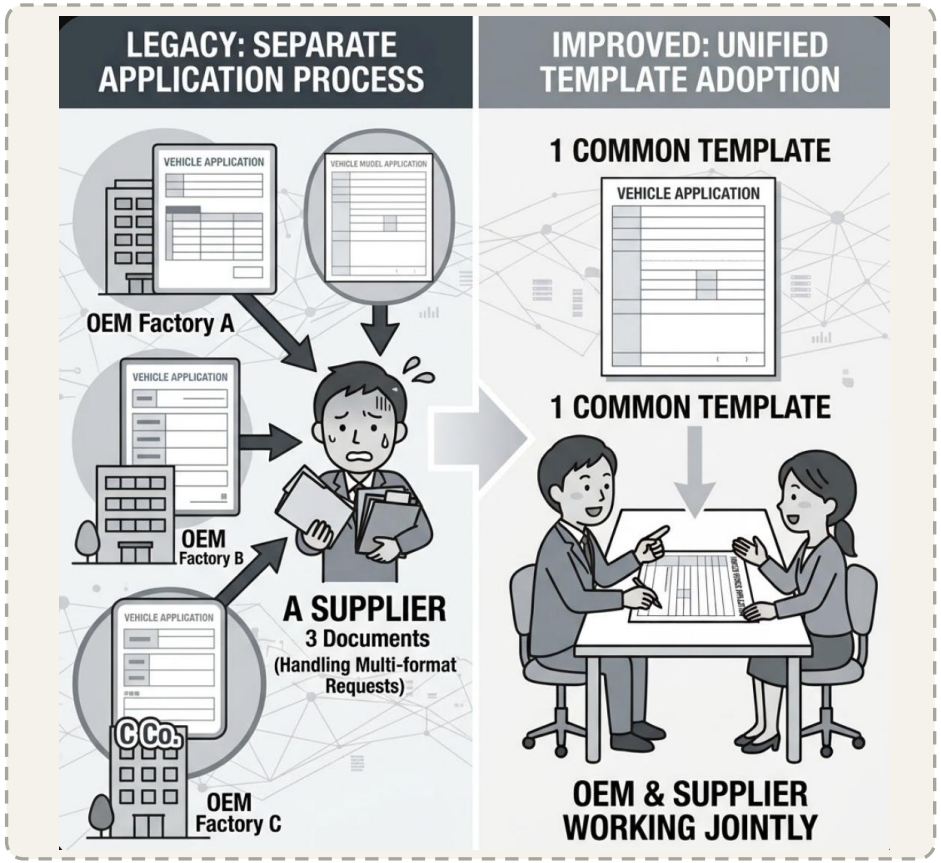
One supply chain, many SBOM "dialects"

Today

- Each OEM asks for different fields and granularity
- "Supplier" means different things to different teams
- Suppliers rebuild the same SBOM again and again

With a shared framework

- One set of fields, one meaning, any mainstream format
- Tools built against one set of requirements



Standards: NTIA 2021 · CISA · BSI TR-03183 · J-Auto-ISAC · 2026 Minimum Elements
Formats: SPDX 2.x · SPDX Lite · SPDX 3.x · CycloneDX 1.4–1.7

Our purpose: a best practice, not a new standard

What it is

- ✓ A best practice by the industry, for the industry
- ✓ Built on existing standards and guidance
- ✓ Independent of format, tool, and organization
- ✓ Open: public on GitHub under CC BY 4.0

What it is not

- ✗ A new SBOM standard or format
- ✗ A competitor to SPDX or CycloneDX
- ✗ A regulation or a certification scheme
- ✗ A way for one company to gain an edge

Collaborate where we don't compete — solve shared problems once, as one industry.

All meetings follow the Linux Foundation antitrust policy.

Automotive SBOM

Three layers of the framework

1

Data Fields

What to record

16 fields: 4 for the SBOM, 12 for each component

2

Automation Support

How to express it

Mapping to SPDX and CycloneDX, with examples

3

Practice and Process

How to operate it

Create, exchange, combine, and use SBOMs

Design principles

- Format independent
- Tool independent
- Organization independent
- Compatible with standards
- Ready for automation

Our journey so far

Nov 2025	Action plan at the OpenChain Automotive WG
Dec 2025	Kick-off; first draft published on GitHub
Jan–Feb 2026	Draft moved to Markdown; project restarted
Mar 2026	Japanese-speaking feedback session
Apr, Jun 2026	Updates at the Governance Monthly meeting
Jul–Sep 2026	Issue-by-issue review on GitHub
Oct 2026	**v1.0 published**

64

pull requests merged since July 2026

62 of them in September

About 150 issues and PRs

Open to everyone

Toward v2.0: five themes

1	**Vulnerability and VEX**	Point to components without ambiguity
2	**Functional safety**	Link security fixes to safety impact
3	**AI-generated code**	OSS snippets slipping into code
4	**AIBOM**	AI models and datasets as components
5	**Proprietary and COTS**	Transparency without exposing IP

Continuing in v1.x

- Practice sections: request, generate, operate SBOMs
- Comparison with Catena-X
- 2026 Minimum Elements items (e.g., signature, tool)

Roadmap and how to take part

Oct 2026
v1.0 published

Oct 7–9, 2026
OSS Summit Europe

Dec 7–9, 2026
OSS Summit Japan

2027
v2.0 drafting (proposed)

Take part

GitHub: github.com/OpenChain-Project/Automotive-SBOM

Mailing list: lists.openchainproject.org/g/automotive-sbom

Meetings: Automotive OSS Governance Monthly

Bring an issue, a PR, or an agenda item.

Thank you

Questions and comments are welcome.

SEPIA – SBOM Exchange Procedures, Interfaces and Architecture

README License

SBOM-sg-SEPIA

The team at Bosch were working on a mapping of SPDX and CycloneDX on both property level (= syntax) and a semantic interpretation of the information. They wrote a schema that describes a bare minimum SBOM on semantic level, and a validator for this. This repo is to explore the work done.

SEPIA – SBOM Exchange Procedures, Interfaces and Architecture

Introduction

SEPIA is a project which focuses on validating SBOMs by using standard SBOM schemas.

Additionally, we would like to curate an Open SBOM schema library by collecting schemas used across industry.

It also provides a tooling which helps to validate SBOM schemas and perform operations such as Edit the metadata, Insert missing fields,Merge multiple SBOMs and Conversion between SEPIA CycloneDX v1.6 & SEPIA SPDX v2.3 SBOMs.

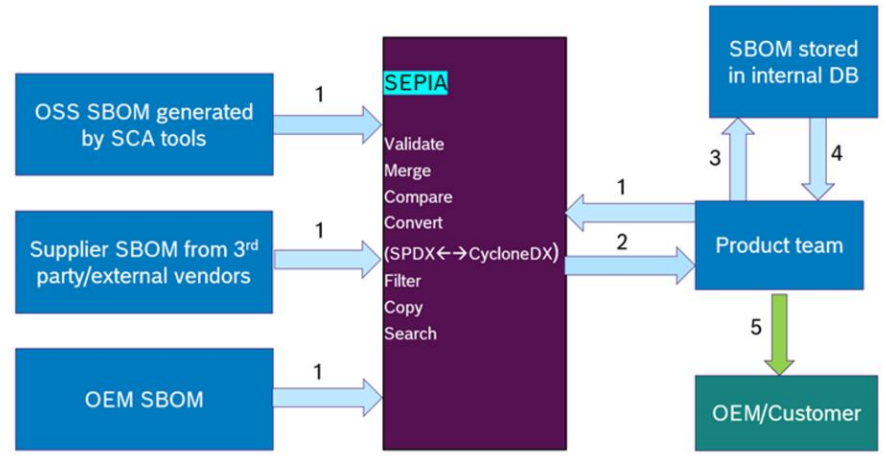
Overview

Category	Feature	Description
Input types	Upload SBOM File	User can upload an SBOM file in JSON format. Supported versions are: • CycloneDX – v1.4 • SPDX – v2.3 • SEPIA SPDX – v2.3 • SEPIA CycloneDX – v1.6 • Custom Schema • Automotive SPDX – v2.3 • Automotive CycloneDX – v1.6
Operations	Validate	Validate the uploaded SBOM against the corresponding schema. If no errors are found, the BOM is valid. Otherwise, the file is not valid and the errors or missing properties are displayed.

■ SEPIAとは

SBOMの相互運用性と品質向上を目的としたプロジェクト

- **SPDXとCycloneDXの意味（セマンティクス）を整理**
- **共通スキーマ（Semantic SBOM）を定義**
- **SBOMの妥当性を検証するValidatorを提供**
- **業界別SBOMスキーマライブラリの整備を目指す**



SEPIA workflow





OPENCHAIN

Thank you